

OXYPC INVENTORY LIFECYCLE

ARCHITECTURE

Permission & Security Rules

Who can see and do what, and how the app protects its data.

Last updated: 6 Nov 2026 · Source: staging branch @ 55ce58a

App Development Team · Bluemonk

Permission & Security Rules

Last updated: 6 Nov 2026 · Source: staging branch @ 55ce58a

In this document: Part A — Role & Permission Matrix · Part B — Security & Access Design

PART A

Role & Permission Matrix

This document shows who can open which page and who does what in the OxyPC Inventory Lifecycle app. It is built from the code, not from the database. The live Permission Matrix in production can narrow (or widen) what is shown here. Every row cites the file that enforces it. Anything the code cannot prove is listed under **Open questions**.

---

1. How permissions work

The app has three layers that stack on top of each other. **Built-in roles** are the 12 values of `UserRole` (`models/user.py:13-25`). Each router has a hard-coded allow-list of built-in roles (`require_roles(...)` in `auth/dependencies.py:175-198`, or an in-handler check such as `if current_user.role not in FINANCE_ROLES` in `routers/accounts.py:31,64`). Admin always passes. **Custom roles** are free-text role names an admin creates (`CustomRole`, `models/role_permissions.py:37-45`; users store the role as text via `RoleType`, `models/user.py:53-65`). A custom role passes every `require_roles` gate that is not admin-only (`auth/dependencies.py:188-189`), but it does **not** pass in-handler checks that compare against built-in roles. `sub_admin` is seeded as a custom role on every start-up (`main.py:582-597`); `trc_manager` exists in the production database (CLAUDE.md) but is not created by code. **The per-page Permission Matrix** (Admin Settings → Master Data → Permission Matrix, `routers/master.py:841-895`) stores one row per role and module (`RoleModulePermission`, `models/role_permissions.py:19-34`). It drives the sidebar (`has_perm()` in `templates/base.html`) and module-gated routes (`require_module_perm`, `auth/dependencies.py:208-232`). It is **permissive by default**: a role or module with no row is allowed (`has_perm`, `models/role_permissions.py:221-240`), except the default-off modules (`DEFAULT_DISABLED_MODULES`, `models/role_permissions.py:215-218`). Only the **Enable** tick is enforced; the Add/Edit/Upload ticks are display-only (`models/role_permissions.py:225-230`). An explicit Enable row can also *widen* a built-in role past a router allow-list, including admin-only pages (`_matrix_grants_path`, `auth/dependencies.py:147-172, 190-196`). A separate tab, **Role Additional Permissions**, holds app-wide switches (Add Lot/IQC/GRN, Edit Devices/IQC/Lot/GRN, Pricing Visibility, Set Price, Upload/Download/Export/Print) — also permissive by default (`has_additional_perm`, `models/role_permissions.py:177-186`).

Practical rule: a page is reachable when **the route gate lets the role in** (hard-coded list, custom-role pass-through, or explicit matrix grant) **and** no matrix row disables it. The sidebar link is shown by `has_perm()` alone, so a link can appear for a built-in role that the route then refuses with 403.

2. Persona → role mapping

#	Persona (business)	Role value in code	Label shown in app	Notes
1	IQC Inspector	`iqc_inspector`	IQC Handler	`models/user.py:16,31`
2	Inventory Manager	`inventory_manager`	Inventory Manager	`models/user.py:15,30`
3	Production Manager	**None.** `inventory_manager` acts as Production Manager	—	"production_manager is NOT a role in this system — it is a module/page name" (`routers/repair.py:47-52`). The string is listed in `FULL_QUEUE_ROLES` in case a custom role of that name is created (`routers/repair.py:59`).
4	Repair Engineer L1/L2	`l1_engineer` (`l2_engineer` is legacy)	L1/L2 Engineer, L2 Engineer	`models/user.py:17-18,32-33` . L2 pages are retired (`routers/repair.py:40-43`).
4	Repair Engineer L3/L4	`l3_engineer`	L3/L4 Engineer	`models/user.py:19,34`
5	QC Inspector (Stress Test, OS install, diagnose)	`qc_inspector`	QC Handler	`models/user.py:20,35`
6	Cosmetic Lead	`cosmetic_manager`	Cosmetic Manager	`models/user.py:25,40` . Missing from `_ROLE_DISPLAY` in `templates_config.py:261-273` and from `ROLE_PERMISSIONS` in `auth/dependencies.py:16-41` .
7	Final QC Inspector	**None.** Final QC page admits `qc_inspector` and `cosmetic_manager`	—	`routers/cosmetic.py:40-41`
8	Spare Parts Manager	`spare_parts_manager`	Parts Manager	`models/user.py:22,37`
9	Sales Executive	`sales` , `sales_manager` , `telecaller`	Sourcing Sales, Sales Manager, Telecaller Sales	`models/user.py:21,23-24`

#	Persona (business)	Role value in code	Label shown in app	Notes
10	Accounts	**None.** Finance pages admit `admin`, `inventory_manager`, `sales_manager` only	—	`routers/accounts.py:31`
11	Managers / Admin	`admin` (plus custom `sub_admin`)	Admin / Sub Admin	`models/user.py:14`; `main.py:582-597`
12	TRC Manager	custom role `trc_manager`	TRC Manager (prettified)	Not seeded by code; referenced in `routers/repair.py:59` and `models/role_permissions.py:248-269`.

3. Page access matrix (code defaults)

3.1 How to read the table

Cells

Cell	Meaning
F	Full: can open the page and use its actions.
V	View: can open the page; actions are refused or not offered.
—	Refused (403 or redirect) by code. For a built-in role, an explicit matrix grant can still open it (`auth/dependencies.py:190-196`).
C	Configurable only: off by default; admin must enable it in the matrix.
U	Link hidden in the sidebar, but the URL itself opens for any signed-in user.
a/b	Engineer column: L1/L2 / L3/L4.
a/b/c	Sales column: `sales` / `sales_manager` / `telecaller`.

Gate type (the "Gate" column says where every cell in that row comes from)

Gate	Source of the cell values
H	Hard-coded role check in the router (`require_roles` or an in-handler role list).

Gate	Source of the cell values
O	Open to any signed-in user (`get_current_user` only).
M	Module permission (`require_module_perm` / `has_perm`); permissive until an admin unticks it. Cells show the default **F**.
S	Seeded default: a migration script wrote `can_enable=False` rows for every non-admin role.
D	Default-disabled in code (`DEFAULT_DISABLED_MODULES`). Configurable only.
A	Admin-only route; any role can be granted it with an explicit matrix row.

Columns. Prod Mgr uses `inventory_manager` values (see §2). Final QC, Accounts and TRC Mgr have no built-in role, so their columns show what **a custom role** gets from code before any matrix row narrows it. For `trc_manager` the production matrix is known to be configured (`models/role_permissions.py:248-269` mentions "~100 OTHER modules"), so its real access may be narrower.

3.2 Matrix

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
Admin Dashboard	O	`routers/dashboard.py` (`/dashboard`); role widgets `:534-604`	V	V	V	V	V	V	V	V	V/V/V	V	F	V
Inventory Search	O view, H edit	`routers/devices.py:39-40` , `:2099`	V	F	F	V	V	V	F	V	V/V/V	F	F	F
TRC Dashboard	H	`routers/dispatch.py:31-32`	—	F	F	—	—	—	F	—	F/F/F	F	F	F
ATTENDANCE › My Attendance	O	`routers/attendance.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
ATTENDANCE › Attendance Report	O (wider scope for privileged)	`routers/attendance.py:23-24,418-428`	V	F	F	V	V	V	V	V	V/V/V	V	F	V
INTAKE › GRN with Invoice	H	`routers/grn.py:32` ; Add/Edit GRN switches `:964,1103`	—	F	F	—	—	—	F	—	—/—/—	F	F	F

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
INTAKE › GRN post IQC	H	`routers/grn.py:32`	—	F	F	—	—	—	F	—	—/—/—	F	F	F
INTAKE › Lot Overview	H	`routers/stock.py:47-48` ; Add/Edit Lot `:433,550`	—	F	F	—	F	—	F	—	—/F/—	F	F	F
INTAKE › IQC Line Items	O list + new IQC; H export/bulk edit	`routers/iqc.py:1405-1422` (open entry); `:170-171` , `:927`	F	F	F	V[1]	V[1]	V[1]	F	V[1]	V[1]/F/V[1]	F	F	F
INTAKE › GRN Records	H	`routers/grn.py:32`	—	F	F	—	—	—	F	—	—/—/—	F	F	F
INTAKE › Entity Movement	M	`routers/entity_movement.py:32`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
INVENTORY › Stock Inwards	H	`routers/stock.py:47-48`	—	F	F	—	F	—	F	—	—/F/—	F	F	F
INVENTORY › Scrap Products	H	`routers/scrap.py:20-21`	—	F	F	—/F	—	—	F	—	F/F/—	F	F	F
INVENTORY › Inventory Request	H view/raise; approve open	`routers/dispatch.py:31-37`	—	F	F	—	—	—	F	—	F/F/F	F	F	F
INVENTORY › Model Requested	O	`routers/model_requested.py`	V	V	V	V	V	V	V	V	V/V/V	V	F	V
INVENTORY › Production Manager	H page; H bucket assign	`routers/stock.py:47-48` (`/trc-production`); `routers/buckets.py:26`	—	F	F	—	V	—	F	—	—/V/—	F	F	F
INVENTORY › Extended Warranty	M	`routers/extended_warranty.py:37`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
INVENTORY › Part Estimation	M	`routers/part_estimation.py:45`	F	F	F	F	F	F	F	F	F/F/F	F	F	F

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
INVENTORY › Move Device	O list; H create	`routers/transfers.py:28-29`	V	F	F	V	F	V	F	V	V/F/V	F	F	F
REPAIR › L1 Repair	O page; M actions	`routers/repair.py:966-969` ; `:229,1369,1453`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
REPAIR › L3/L4 Repair	O page; M actions	`routers/repair.py:687-690` ; `:826`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
REPAIR › Stress Test	H	`routers/qc.py:28-29` ; `qc_check` add	—	—	—	F/F	F	—	F	—	—/F/—	F	F	F
REPAIR › Cosmetic & Paint / Cosmetic Stage	H	`routers/cosmetic.py:40-41` ; stage roles `:221-240`	—	F	F	—	F	F	F	—	—/F/—	F	F	F
REPAIR › Final QC	H	`routers/cosmetic.py:40-41` ; `cosmetic_finalqc`	—	F	F	—	F	F	F	—	—/F/—	F	F	F
REPAIR › WorkID Status	O	`routers/workid_status.py`	V	V	V	V	V	V	V	V	V/V/V	V	F	V
STORE MANAGER › Parts Dashboard / Parts Sale Request	H	`routers/part_sales.py:40-41,263,577`	—	—	—	—	—	—	F	F	F/F/—	F	F	F
STORE MANAGER › Parts Manager	H	`routers/spare_parts.py:32-33`	—	—	—	—	F	—	F	F	—/F/—	F	F	F
STORE MANAGER › Parts GRN	H	`routers/parts_grn.py:26`	—	—	—	—	—	—	F	F	—/—/—	F	F	F
Inventory Locations › Location Map	O	`routers/inventory_location.py` (`/locations/dashboard`)	F	F	F	F	F	F	F	F	F/F/F	F	F	F
Inventory Locations › Physical Audits	O	`routers/physical_audits.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
Inventory Locations › Gap Alerts	O	`routers/inventory_location.py` (`/locations/gaps`)	V	V	V	V	V	V	V	V	V/V/V	V	F	V
Inventory Locations › Zone Audit	H create/close; O scan	`routers/inventory_location.py` (`/locations/audit*`)	V	F	F	V	V	V	F	V	V/V/V	F	F	F
Inventory Locations › Manage Locations	H	`routers/inventory_location.py` (`/locations/master*`)	—	F	F	—	—	—	F	—	—/—/—	F	F	F
Inventory Locations › Trash	H	`routers/trash.py:27`	—	F	F	—	—	—	F	—	—/—/—	F	F	F
CRM › Procure Dashboard	O view; H actions	`routers/procure_dashboard.py:31,48`	V	V	V	V	V	V	V	V	V/F/V	V	F	V
CRM › Contact Leads	O	`routers/crm_contacts.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
CRM › Sourcing Deals	O	`routers/crm_sourcing.py:33,68`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
CRM › Sales Opportunities / Quotes	O	`routers/crm_sales.py:58` ; `routers/crm_quotes.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
CRM › Price Matrix	O view; H edit (in-handler)	`routers/crm_price_matrix.py:25,55,67`	V	F	F	V	V	V	V	V	V/F/V	V	F	V
CRM › Purchase Orders	H (in-handler)	`routers/crm_purchase_orders.py:26-29,58,87`	—	F	F	—	—	—	—	—	V/F/V	—	F	—
CRM › CRM Analytics	O	`routers/crm_reports.py`	V	V	V	V	V	V	V	V	V/V/V	V	F	V

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
CRM › Assign Social Leads	O	`routers/crm_assign_leads.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
EXTERNAL PARTNER › Partner Accounts, Listings Manager, Bids Created, Manage Lots, Bookings Queue, My Desk, Portal Settings	S	`migrate_seed_trade_partner_split_perms.py` ; `routers/partner_admin.py`	—	—	—	—	—	—	—	—	—/—/—	—	F	—
EXTERNAL PARTNER › Margin Floors	S + sidebar admin-only	`templates/base.html:407`	—	—	—	—	—	—	—	—	—/—/—	—	F	—
EXTERNAL PARTNER › All Deals	M (not in the seed list)	`routers/deals.py:23`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
CUSTOMER CARE › Ticket Queue, Device Pairings, Provision Device, Offers, Pilot Dashboard	M	`routers/care_admin.py` (`care_support`)	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SALES & CRM › TeleSales Dashboard	M	`routers/telesales_dashboard.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SALES & CRM › Dealers	H	`routers/dealers.py:73-77` ; manage `:80-100`	—	—	—	—	—	—	F	—	F/F/F	F	F	F
SALES & CRM › Telecalling	O (own records unless manager)	`routers/telecalling.py:79,234,448`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SALES & CRM › Quotations	M	`routers/quotations_list.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SALES & CRM › Model Requests	O list; H raise/fulfil	`routers/model_requests.py` (`REQUEST_ROLES` , `FULFIL_ROLES`)	V	F	F	V	V	V	F	V	F/F/F	F	F	F

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
SALES & CRM › Assign Dealer Leads	M	`routers/assign_dealer_leads.py:26`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SELLING › Ready to Sale	O view; H sell; Set Price switch	`routers/sales.py:79,85,1395` ; `:718-742,940,980`	V	V	V	V	V	V	F	V	F/F/F	F	F	F
SELLING › Ready to Sale Parts	H	`routers/part_sales.py:40-41,128`	—	—	—	—	—	—	F	F	F/F/—	F	F	F
SELLING › Scrap for Sale	H	`routers/scrap_for_sale.py:33`	—	F	F	—	—	—	F	—	—/F/—	F	F	F
SELLING › Sales List	H; hard delete admin-only	`routers/sales.py:79` ; `:1780-1805`	—	—	—	—	—	—	F	—	F/F/F	F	F	F
SELLING › Spare Part Sales	H	`routers/part_sales.py:40-41`	—	—	—	—	—	—	F	F	F/F/—	F	F	F
SELLING › Scrap Sale Report	D	`models/role_permissions.py:215-218`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
SELLING › Block Tags	M	`routers/block_tags.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SELLING › Gate Pass	H	`routers/gate_pass.py:38-39`	—	F	F	—	—	—	F	—	F/F/—	F	F	F
SELLING › Credit Note	M	`routers/sales.py:3230-3479`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
SELLING › Returns	H; approve/reject in-handler	`routers/sales.py:79,2554-2681` ; `:3521,3545-3553`	—	—	—	—	—	—	F²	—	F²/F/F²	F²	F	F²
FINANCE › Accounts, Supplier Payments, Customer Receipts	H (in-handler)	`routers/accounts.py:31,64-65,109`	—	F	F	—	—	—	—	—	—/F/—	—	F	—
FINANCE › Partner Payments	H	`routers/partner_payments.py:28`	—	—	—	—	—	—	F	—	—/F/—	F	F	F

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
Terms & Conditions	A	`routers/terms_conditions.py:16` ; `templates/base.html:565`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
Company Setting	H (in-handler, admin)	`routers/settings.py:55,93,142` ; `templates/base.html:570-574`	—	—	—	—	—	—	—	—	—/—/—	—	F	—
Cost Config	M	`routers/admin.py:545,563`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
PRODUCT MASTER › Product Master, Pricing Calculator, Hardware, Spare Parts, Product Pricing	D	`models/role_permissions.py:215-218` ; `routers/product_master.py`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
REPORTS › Business P&L, Lot P&L	H (two gates)	`routers/reports.py:43-47,60-63,66-69`	—	F	F	—	—	—	F	—	—/—[3]/—	F	F	F
REPORTS › Sales Report, Daily Stock, Stage Log	H (router gate)	`routers/reports.py:43-47,66-69`	—	F	F	—	F	—	F	—	F/—[3]/—	F	F	F
ADMIN › Users, Master Data, Sidebar Config, Module Page Titles, Group Config	A	`routers/admin.py:100` ; `routers/master.py:25` ; `routers/sidebar_config.py` ; `routers/landing_pages.py` ; `routers/attendance_group_config.py:23`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
ADMIN › Move Device Internal	O route; link admin/explicit	`routers/repair.py:1772,1790` ; `templates/base.html:691`	U	U	U	U	U	U	U	U	U/U/U	U	F	U

Sidebar section › Page (label in `templates/base.html`)	Gate	Source	IQC	Inv Mgr	Prod Mgr	Repair Eng	QC	Cosmetic	Final QC	Spares	Sales S/M/T	Accounts	Admin	TRC Mgr
ADMIN › QA Dashboard	O view, H edit; link admin-only	`routers/qa_uat.py:54-56` ; `templates/base.html:719-723`	U	U	U	U	U	U	U	U	U/U/U	U	F	U
Application Settings › Stage Control, Stage Audit Log	A	`routers/stage_control.py:23`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
Application Settings › Aging Tracker	O	`routers/stage_control.py` (`/stage-control/aging`)	V	V	V	V	V	V	V	V	V/V/V	V	F	V
Application Settings › System Audit Log	A	`routers/admin.py:444-451`	C	C	C	C	C	C	C	C	C/C/C	C	F	C
Application Settings › Stock Aging, Overdue Devices	H (router gate)	`routers/reports.py:43-47`	—	F	F	—	F	—	F	—	F/—[3]/—	F	F	F
Application Settings › Receivables	H (two gates)	`routers/reports.py:50-53`	—	F	F	—	—	—	F	—	—/—[3]/—	F	F	F
Application Settings › Market Intel	O	`routers/market.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F
Application Settings › Parts Purchased, Parts Tracking	H	`routers/spare_parts.py:32-33`	—	—	—	—	F	—	F	F	—/F/—	F	F	F
Application Settings › Parts Consumption	O	`routers/spare_parts.py` (`/spare-parts/consume`)	F	F	F	F	F	F	F	F	F/F/F	F	F	F
NOTIFICATIONS › Alerts; SUPPORT › Tickets Raised, Manuals	O	`templates/base.html:821-841` ; `routers/notifications.py` , `routers/tickets.py` , `routers/manuals.py`	F	F	F	F	F	F	F	F	F/F/F	F	F	F

Footnotes

1. **V**[1] — the role can open the IQC list and register a new IQC device (open to every signed-in user, `routers/iqc.py:1412-1422`), but cannot export or bulk-edit grades (`routers/iqc.py:170-171,927`).
2. **F**[2] — can view and raise returns; only `admin` and `sales_manager` can approve or reject (`routers/sales.py:3521,3553`). Custom roles are refused at that step because the check compares built-in roles.
3. **—**[3] — `sales_manager` is in the financial gate (`routers/reports.py:60-63`) and the receivables gate (`:50-53`) but **not** in the router-level gate (`:43-47`) that every `/reports` page also passes. By code reading, a `sales_manager` with no explicit matrix row for a reports module gets 403. QA test TC-254-1 expects 200 for `sales_manager` (`seed_qa_july16_batch.py:247-250`), so production likely relies on a matrix grant. See Open questions.

What the table does **not** show:

- **Sidebar vs route.** For every **H** row, the sidebar link still appears for a built-in role that has no matrix row, because `has_perm()` is permissive (`models/role_permissions.py:234-238`). The user then sees the 403 page (`main.py:381-383`).
- **Global Visibility.** An admin can hide any module from everyone, admin included (`_MODULE_HIDDEN_CACHE`, `models/role_permissions.py:151-166`; `templates_config.py:225-233`).
- **WA Audit Log / WhatsApp.** The WhatsApp router is no longer registered (`main.py`, "WhatsApp integration removed"), so these links lead nowhere.
- **Add/Edit/Upload ticks.** They are saved but do not restrict anything (`models/role_permissions.py:225-230`; only "Enable" is offered, `routers/master.py:303-305`).

4. Sensitive data rules

Data	Rule in code	Where it is enforced	Gaps found
Buying price, sale price, cost, margin (screens)	**Pricing Visibility** switch per role (`can_view_pricing`, default on for every role). Admin always sees prices. Policy (1 Nov 2026): management roles only — see Security & Access Design, Pricing and financial data policy. Current default does not comply.	Column `RoleAdditionalPermission.can_view_pricing` (`models/role_permissions.py:83`); check `can_view_pricing()` (`:189-193`); saved by `routers/master.py:946-986`. Used in 21 templates (e.g. `templates/sales/list.html:171`, `templates/lots/list.html:81-117`, `templates/iqc/list.html:195-223`) and in server JSON (`routers/sales.py:218,2112`; `routers/devices.py:527,1190`).	Not applied to CSV exports: `/sales/export` (`routers/sales.py:2331`), `/sales/export-selected` (`:1953`), `/reports/export/sales` (`routers/reports.py:1121`), `/reports/export/lot-pl` (`:870`).

Data	Rule in code	Where it is enforced	Gaps found
Setting a selling price	**Set Price** switch per role (default on).	`routers/sales.py:718-742,940,980` (server-side 403).	—
Company and lot P&L	Only `admin`, `inventory_manager`, `sales_manager` by the financial gate. The page also hides content when Pricing Visibility is off. Policy (1 Nov 2026): management roles only — see Security & Access Design, Pricing and financial data policy. Current default does not comply.	`routers/reports.py:55-63` ("Flagged in the 2026-07-15 RBAC audit"); `templates/reports/lot_pl.html:5-8`; QA defect BUG-212 (`seed_qa_july16_batch.py:348-352`).	Custom roles pass the financial gate (`auth/dependencies.py:188-189`).
Supplier payments, customer receipts	Only `admin`, `inventory_manager`, `sales_manager`.	`routers/accounts.py:31,64-65` (in-handler).	A custom "Accounts" role cannot open these pages.
Cost Config (cost rates)	Module `cost_config`, permissive by default.	`routers/admin.py:545,563`.	Open to every role until an admin unticks it.
Margin floors (partner portal)	Admin-only link; module seeded off.	`templates/base.html:407`; `migrate_seed_trade_partner_split_perms.py`.	—
Exports, downloads, uploads, printing	App-wide switches exist (File Upload/Download/Export/Print).	Stored and cached only (`routers/master.py:313-325,898-940`).	**No route or template reads them.** Exports are limited only by the page's own gate and a 5,000-row cap (`routers/reports.py:40`).
Per-user permissions (`UserPermission`)	Admin can tick per-user grants such as "View Device Buying / Cost Data".	Stored by `routers/admin.py:375-430`; model `models/user.py:133-143`.	**Not enforced anywhere** (only `routers/admin.py` reads the table).
Hard delete of sales	Admin only; audited with old values.	`routers/sales.py:1780-1805`.	—

5. RACI for key business events

R (Responsible) comes from code: the roles the routes let perform the action. **A, C, I** are **proposed** from the persona list; the code does not model accountability or notifications for these events. Please confirm.

Event	R — who code lets do it	A (proposed)	C (proposed)	I (proposed)	Audit record written
Lot intake (GRN with invoice, create lot)	GRN: `admin`, `inventory_manager` (`routers/grn.py:32`). Create lot: `admin`, `inventory_manager`, `qc_inspector`, `sales_manager` + Add Lot switch (`routers/stock.py:47,433`). Custom roles pass both.	Inventory Manager	Accounts (invoice)	Production Manager, IQC	`GRN_SUBMITTED`, `GRN_CREATED_MANUAL`, `LOT_CREATED` (`services/audit_engine.py` callers in `routers/grn.py`, `routers/stock.py`)
IQC registration	Any signed-in user + Add IQC switch (`routers/iqc.py:1412-1422`).	IQC Inspector	Inventory Manager	Production Manager	`DEVICE_IQC_REGISTERED` (`routers/iqc.py:1648`)
Repair (L1/L2, L3/L4)	Any signed-in user whose matrix does not disable `repair_l1` / `repair_l3` (`routers/repair.py:229,826,1369,1453`). Part requests: `admin`, `inventory_manager`, L1/L2/L3 engineers (`routers/part_requests.py:29`); hand-over: `admin`, `spare_parts_manager`.	Production Manager	Spare Parts Manager	QC Inspector	`REPAIR_STARTED`, `REPAIR_COMPLETE`, `REPAIR_PNA`, `STAGE_MOVED`
QC pass / fail (Stress Test)	`admin`, `qc_inspector`, `sales_manager`, L1/L2/L3 engineers (`routers/qc.py:28-29`) + `qc_check` module.	QC Inspector	Repair Engineer	Production Manager	`QC_PASS` / `QC_FAIL` with score and grade (`routers/qc.py:321-325`); `STRESS_FAIL_ASSIGNED` (`routers/stress_api.py:643`)
Grading	At IQC entry (any signed-in user); bulk grade/type: `admin`, `inventory_manager`, `iqc_inspector`, `sales_manager` + Edit Devices/IQC switch (`routers/iqc.py:170,927`); Final QC edit: cosmetic gate (`routers/cosmetic.py:40`).	QC / Final QC Inspector	Cosmetic Lead	Sales	`IQC_BULK_GRADE_TYPE_APPLIED` (`routers/iqc.py:1166`)
Sale	`admin`, `sales`, `sales_manager`, `telecaller` + `sales` module (`routers/sales.py:79,1395`).	Sales Manager	Accounts	Inventory Manager	`SALE_CREATED`; event `SALE_COMPLETED`
Gate pass (exit)	`admin`, `sales_manager`, `sales`, `inventory_manager` (`routers/gate_pass.py:38-39`).	Inventory Manager	Sales	Accounts	`GATE_EXIT_CONFIRMED`, `GATE_EXIT_BULK_CONFIRMED` (`routers/gate_pass.py:364,411`)
Return / credit note	Raise: sales roles + `returns` module (`routers/sales.py:2665-2681`). Approve/reject: `admin`, `sales_manager` (`:3545-3553`). Credit-note stages: `credit_note` module, open by default (`:3335-3341`).	Sales Manager	Accounts, QC	Inventory Manager	`RETURN_SUBMITTED`, `RETURN_APPROVED`, `RETURN_REJECTED`, `CREDIT_NOTE_STAGE_ADVANCED`
Warranty extension	`extended_warranty` module, open by default (`routers/extended_warranty.py:37`).	Sales Manager	Accounts	Customer Care	`WARRANTY_SET`, `WARRANTY_EXTENDED` (`routers/extended_warranty.py:118,159`)

Event	R — who code lets do it	A (proposed)	C (proposed)	I (proposed)	Audit record written
Stock audit (physical / zone)	Physical Audits: any signed-in user (`routers/physical_audits.py`). Zone audit create/close: `admin` , `inventory_manager` ; scan: any (`routers/inventory_location.py`).	Inventory Manager	Production Manager	Admin	Stored as audit records (`models/audit_record.py`); `STOCK_VALIDATE` for stock validation
System audit review	System Audit Log: admin, or explicit grant (`routers/admin.py:444-451`).	Admin	—	Director	Read-only view of `audit_logs`

6. Open questions

1. **Production matrix.** What rows does the live `role_module_permissions` table hold per role? This document shows code defaults only. An export of that table would let us replace defaults with real values.
2. **Missing roles.** Should Production Manager, Final QC Inspector and Accounts become built-in roles or custom roles? Today a custom "Accounts" role is refused by `routers/accounts.py:64-65` , and a custom role gets almost every non-admin page by default (`auth/dependencies.py:188-189`).
3. `sub_admin` **default.** `main.py:585-587` says a fresh `sub_admin` "sees nothing extra". By code reading it gets every permissive module and passes every non-admin `require_roles` gate. Is that intended?
4. `sales_manager` **and reports.** Should `sales_manager` be added to the router-level reports gate (`routers/reports.py:43-47`), or is the matrix grant the intended route?
5. **Admin-equivalent grants.** An explicit grant of `admin_master` or `admin_users` opens the Permission Matrix or User Management (via `routers/landing_pages.py:176-177` and `auth/dependencies.py:166-168`). Who may hold these?
6. **Repair pages.** `stage_allowed()` (`routers/repair.py:76-85`) is defined but not used, so L1 and L3/L4 pages are open to every role. Is that intended?
7. **Pricing on exports.** Answered by the policy of 1 Nov 2026: yes, exports (and printouts) must strip price, cost and margin columns for non-management roles. See Security & Access Design, Pricing and financial data policy. Management role list confirmed 1 Nov 2026 (Security & Access Design §9.1); Production Manager keeps parts cost for lot estimation.
8. **Export/Download/Print switches.** Should these be enforced, or removed from the UI?
9. **Cost Config and Credit Note defaults.** Should these sensitive modules start off (add to `DEFAULT_DISABLED_MODULES`)?
10. `trade_partner_all_deals` **.** It is missing from the seed list in `migrate_seed_trade_partner_split_perms.py` , so All Deals is open by default. Intended?
11. **RACI.** Please confirm the proposed A / C / I columns in §5.

PART B

Security & Access Design

This document explains how the OxyPC Inventory Lifecycle app signs people in, decides what they may do, protects forms, limits abuse, records what happened, and stores secrets and files. It also lists the security risks found while reading the code. Every claim cites a file. Anything the code cannot prove is listed under **Open questions**. For the page-by-page access table, see Role & Permission Matrix.

1. Summary

Area	How it works today	Main source
Staff login	Username + password, bcrypt, JWT in an `httponly` cookie	`routers/auth.py:54-122` ; `auth/dependencies.py:44-90`
Session length	24 hours (1,440 min), fixed in code; can be extended from the page	`config.py:29-33` ; `routers/auth.py:208-234`
Authorisation	Hard-coded role lists + custom roles + per-page Permission Matrix (cached in memory)	`auth/dependencies.py:175-303` ; `models/role_permissions.py`
CSRF	Double-submit cookie (`csrf_token`), `SameSite=strict` cookies	`auth/dependencies.py:306-343`
Rate limiting	SlowAPI: 2,000/min default; 20/min login per IP; 5 failed logins lock an account for 15 min	`limiter.py:74` ; `routers/auth.py:37-38,55`
Audit trail	`audit_logs` table written by `audit()` ; `login_logs` for logins; `event_log` for webhook events	`services/audit_engine.py` ; `models/engines.py:107-125` ; `models/user.py:120-130` ; `models/event_log.py`
Partner portal	Separate dealer login and JWT cookie with `typ: partner`	`auth/partner_auth.py`
Machine access	Hashed, scoped API keys (`/api/v1`), a static OxyQC key, device tokens for the Care Agent	`auth/api_key.py` ; `routers/iqc_api.py:39-40` ; `auth/care_auth.py`

2. Authentication

2.1 Staff login

Step	What happens	Source
1. Open login page	Server issues a fresh `csrf_token` cookie for the login form.	`routers/auth.py:41-51`
2. Submit	`POST /auth/login` checks CSRF and the per-IP limit (20/min).	`routers/auth.py:54-62`
3. Lockout check	If the user has 5 or more `login_failed` rows in the last 15 minutes, login is refused.	`routers/auth.py:37-38,75-88`
4. Password check	bcrypt `checkpw`, run in a thread so it does not block other users.	`auth/dependencies.py:57-83`
5. Failure	A `login_failed` row is written (only for a real username). The message is the same for unknown user and wrong password.	`routers/auth.py:90-97`
6. Disabled account	`status = False` users are refused.	`routers/auth.py:98-99`
7. Success	JWT created with `sub` (username) and `role`; `last_login` updated; `login` row written with IP.	`routers/auth.py:101-108`
8. Cookies	`access_token` (`httponly`, `SameSite=strict`), `csrf_token` (readable by JS), `session_expires` (readable by JS for the warning popup). `Secure` only if `COOKIE_SECURE` is on.	`routers/auth.py:110-122`
9. Landing	Admin → `/dashboard`; everyone else → `/attendance`.	`routers/auth.py:22-33`

2.2 Passwords

Item	Value	Source
Hashing	bcrypt with a per-hash salt (`gensalt()`); input capped at 72 bytes to keep old hashes valid	`auth/dependencies.py:44-65`
Cost	About 410 ms per check at cost 12 (comment)	`auth/dependencies.py:68-77`
Self-service change	Needs current password; minimum 6 characters	`routers/auth.py:174-205`

Item	Value	Source
Admin create / reset	No length or strength check; reset is not written to the audit log	`routers/admin.py:190-236,359-372`

2.3 Session / token

Item	Value	Source
Token type	JWT, HS256, signed with `SECRET_KEY`	`auth/dependencies.py:14,86-90`
Lifetime	1,440 minutes. Env/config values are deliberately ignored.	`config.py:29-33`
Refresh token	`REFRESH_TOKEN_EXPIRE_DAYS` is defined but not used by any route.	`config.py:34` (no other reference in the code)
Each request	Cookie decoded; user re-read from the database; disabled users are sent to login. Role changes therefore apply on the next request.	`auth/dependencies.py:93-109`
Extend session	`GET /auth/extend-session` re-issues all three cookies for another 24 h while the current token is valid.	`routers/auth.py:208-234`
Logout	Deletes the three cookies. The JWT itself stays valid until it expires (no server-side revocation list). Logout is not logged.	`routers/auth.py:125-145`
Back-button safety	HTML responses get `Cache-Control: no-store`.	`main.py:100-109`

3. Authorisation layers

A request passes up to five checks. Admin skips almost all of them.

#	Layer	What it does	Source
1	`get_current_user`	Valid JWT cookie + active user, else redirect to `/auth/login`.	`auth/dependencies.py:93-109`
2	`require_roles(*roles)`	Admin passes. Listed built-in roles pass. **Custom roles pass any gate that is not admin-only.** Built-in roles not listed pass only with an explicit matrix grant for the path's module.	`auth/dependencies.py:175-198`

#	Layer	What it does	Source
3	In-handler role checks	Some routers compare `current_user.role` against a tuple of built-in roles inside the handler (custom roles fail these). Examples: Finance (`routers/accounts.py:31,64`), Purchase Orders (`routers/crm_purchase_orders.py:26-29`), Price Matrix edit (`routers/crm_price_matrix.py:25`), Returns approval (`routers/sales.py:3521,3553`), Company Setting (`routers/settings.py:55`).	as listed
4	Module permission	`require_module_perm` / `has_perm` check the matrix **Enable** bit. No row = allowed (except default-off modules).	`auth/dependencies.py:208-256` ; `models/role_permissions.py:215-240`
5	Additional permission	`require_additional_perm` checks app-wide switches such as Add Lot, Edit Devices, Set Price. No row = allowed.	`auth/dependencies.py:259-303` ; `models/role_permissions.py:177-200`

3.1 Template layer

Helper	Purpose	Source
`has_perm` , `any_perm`	Show a sidebar item or section when the module is enabled.	`templates_config.py:113-153,247-249`
`has_explicit_perm`	Show admin items only for admin or an explicit grant (Sub Admin tab).	`templates_config.py:123-129`
`role_allowed(role, *values)`	Mirror of `require_roles` for buttons in templates, so custom roles see the same buttons the backend allows. CLAUDE.md asks all new role-gated buttons to use it.	`templates_config.py:174-190`
`can_view_pricing` , `can_set_price`	Hide price columns / Set Price buttons.	`templates_config.py:132-149`
`module_hidden`	Global Visibility: hide a module for everyone, admin included.	`templates_config.py:225-233`

3.2 Permission cache

Item	Behaviour	Source
Storage	Module-level dicts `_PERM_CACHE` , `_ADDITIONAL_PERM_CACHE` (and label/visibility caches)	`models/role_permissions.py:102-166`

Item	Behaviour	Source
Load	On start-up from `role_module_permissions` and `role_additional_permissions`	`main.py:570-578` ; `routers/master.py:1110-1131`
Update	Save handlers update the cache of the worker that served the save	`routers/master.py:880-895,932-940`
Other workers	Every worker reloads all caches every 60 s	`main.py:789-829`
Worker count	`main.py:863` and `Dockerfile:71-73` run 1 worker; `deploy/oxypc.service:28` runs 4 workers. With 4, a matrix change can take up to 60 s to reach every worker.	as listed
`sub_admin` seed	Custom role `sub_admin` is created at start-up if missing	`main.py:582-597`

3.3 403 handling

Item	Behaviour	Source
Page requests	`error.html` with title "Access Denied" and the hint "Ask an admin to enable it for your role in Master Data → Module Permissions".	`main.py:325-326,355-365,381-383`
API / AJAX	JSON `{error, code, solution}` (detected by `/api/` path, `Accept` , or `X-Requested-With`).	`main.py:340-352`
Auth redirects	302 from dependencies is turned into **303** to `/auth/login` to avoid POST redirect loops.	`main.py:367-378,386-398`
Debug detail	Exception text is shown only if `OXYPC_DEBUG=1` .	`main.py:26,428,488`

4. CSRF

Item	Behaviour	Source
Pattern	Double-submit: form field `csrf_token` (or header `X-CSRF-Token`) must equal the `csrf_token` cookie. GET/HEAD/OPTIONS/TRACE skip the check.	`auth/dependencies.py:306-343`
Failure	Redirect to login (treated as a timed-out page), not a 403.	`auth/dependencies.py:323-343`

Item	Behaviour	Source
Where applied	Router-level `dependencies=[Depends(verify_csrf)]` on most routers (e.g. `routers/admin.py:99`, `routers/sales.py:67`), or per route (e.g. `routers/accounts.py:192`).	as listed
Logout	Deliberately not CSRF-checked, so logout cannot fail.	`routers/auth.py:125-139`
Partner portal	Parallel cookie `partner_csrf_token`.	`auth/partner_auth.py:76-91`
Cookie-auth POSTs without CSRF (found by scan)	`routers/qa_uat.py` (10 POSTs), `routers/api_v1/api_keys.py`, `routers/api_v1/webhooks.py`, `routers/api_v1/telecalling.py` (`/assignments`, `/calls`), `routers/partner_admin.py` (`/bids/{bid_id}/generate-po`). All cookies are `SameSite=strict`, which blocks normal cross-site posts.	as listed; cookies `routers/auth.py:115-121`

5. Rate limiting and lockout

Limit	Value	Key	Source
Default, all routes	2,000 / minute	Hash of the session cookie, else client IP	`limiter.py:32-49,74`
Staff login	20 / minute	Client IP only (cookie ignored)	`routers/auth.py:55`; `limiter.py:52-60`
Partner login	5 / minute + account lockout	Client IP	`routers/partner_portal.py:74-75,107`
Care Agent pairing	10 / minute	Client IP	`routers/care_api.py:48-49`
Care tickets / diagnostics	10 / 20 per minute	Default key	`routers/care_api.py:193-194,281-282`
Account lockout	5 failures in 15 min	Per username	`routers/auth.py:37-38,75-88`
Client IP	Right-most `X-Forwarded-For` entry (cannot be forged by the client)	—	`limiter.py:11-29`
Storage	In memory (no storage back-end configured) — per worker process	—	`limiter.py:74`

Note: the comment in `main.py:34` says login is "5/min"; the code says 20/min (`routers/auth.py:55`).

6. Audit trail and event log

Store	What is recorded	Written by	Retention	Source
`audit_logs`	user, action, table, record id, old/new JSON, notes, IP, time	`audit()` (caller must commit) — 217 distinct action names across routers and services	No pruning code found	`services/audit_engine.py:23-58`; `models/engines.py:107-125`
`audit_logs` (DB trigger)	Changes to `telecalling_records`, `telecalling_assignments`	Trigger `fn_audit_central`	Same table	`alembic/versions/20260514_1000_telecalling_mobile_pwa.py:44-49,168-210`
`login_logs`	`login`, `login_failed`, IP	Login route	No pruning code found	`models/user.py:120-130`; `routers/auth.py:94-107`
`event_log`	Event type, payload, webhook attempts and last status	Webhook dispatcher, for the 7 subscribed event types	No pruning code found	`models/event_log.py`; `services/webhook_dispatcher.py:94-125`; `main.py:558-567`
Care audit	Pairing and device events	`care_audit()`	Unknown	`routers/care_api.py`
Physical stock audits	Counts per stage/location and per tag	Physical Audits page	— (business data, not a security log)	`models/audit_record.py`
Error log	Full tracebacks for 5xx	Exception handlers	File grows without rotation in code	`main.py:112-119,433-489`

Examples of audited actions: `USER_CREATED`, `USER_DELETED` (`routers/admin.py:231,352`), `SALE_CREATED`, `SALE_DELETED`, `QC_PASS` / `QC_FAIL` (`routers/qc.py:321-325`), `GATE_EXIT_CONFIRMED` (`routers/gate_pass.py:364`), `WARRANTY_EXTENDED` (`routers/extended_warranty.py:159`), `MANUAL_BACKUP`, `DELETE_BACKUP` (`routers/admin.py:703,731`).

Not audited (no `audit()` call found): Permission Matrix, Additional Permissions, Pricing Visibility and Sub Admin saves (`routers/master.py`), Stage Control transitions (`routers/stage_control.py`), Sidebar Config (`routers/sidebar_config.py`), admin password reset (`routers/admin.py:359-372`), logout.

"Append-only" is stated in the model docstring (`models/engines.py:109-110`). No database rule, trigger or `REVOKE` protecting `audit_logs` was found.

7. Partner portal, APIs and agents

Channel	Who	Authentication	Authorisation / scoping	Source
Partner portal `/partner/*`	Dealers	Phone + password (bcrypt); `partner_token` JWT cookie, 12 h; claim `typ: partner`; `pv` (password version) kills old tokens after reset	Every query scoped to the logged-in dealer (e.g. `PartnerBid.dealer_id == dealer.id`); dealer must be `portal_enabled` and `active` on every request	`auth/partner_auth.py:22-73`; `routers/partner_portal.py:74-138,1099-1126`
Partner admin `/trade-partner/*`	Staff	Staff session	Module permissions `trade_partner_*`, seeded off for all non-admin roles	`routers/partner_admin.py:63,231-446`; `migrate_seed_trade_partner_split_perms.py`
Ecosystem API `/api/v1/*`	Other apps	`Authorization: Bearer <key>`; key stored as SHA-256; revocable (`is_active`, `deleted_at`); no expiry field	Per-key scopes (`devices:read`, `iqc:write`, ...)	`auth/api_key.py:122-212`; `models/api_key.py:13-41`
API key and webhook admin	Admin	Staff session	`require_roles(admin)`	`routers/api_v1/api_keys.py:24`; `routers/api_v1/webhooks.py:24`
Mobile telecalling `/api/v1/telecalling/*`	Staff	Staff session	Legacy `ROLE_PERMISSIONS` strings (`tc.*`); custom roles and `cosmetic_manager` have none	`routers/api_v1/telecalling.py:23-39`; `auth/dependencies.py:16-41`
Outbound webhooks	—	HMAC-SHA256 header `X-OxyPC-Signature`; 10 s timeout	Subscribed event types only	`services/webhook_dispatcher.py:25-81`
OxyQC desktop app `/iqc/api/*`	IQC PCs	Static header `X-OxyQC-Key`, default `oxyqc-default-key-change-me`, compared with `!=`	Full access to its endpoints, incl. user list and device submit	`config.py:45`; `routers/iqc_api.py:39-41,88-105,257-261`
Care Agent `/care/api/v1/*`	Customer laptops	One-time provisioning token (single use, expiring, atomic) → long-lived device token (stored hashed)	Every query scoped to the token's pairing	`auth/care_auth.py:1-75`; `routers/care_api.py:48-114`
CORS	Browser apps on listed origins	`allow_credentials=True`; origins from `OXYPC_ALLOWED_ORIGINS` (default localhost ports)	—	`config.py:49-56`; `main.py:43-52`
FieldOps `/fieldops`	Separate app	Own database and accounts	Out of scope here	`main.py:497-513`; `routers/fieldops.py`

8. Data protection

Topic	What the code does	Source
Secrets	Read from env vars first, then `config.ini`, then code defaults. `.env` and `config.ini` are git-ignored.	`config.py:1-56`; `.gitignore:2-5`
Code defaults	DB URL with password `oxypc123`; OxyQC key `oxyqc-default-key-change-me`; random `SECRET_KEY` written to `config.ini` on first run.	`config.py:27-28,45,58-69`; `main.py:28-30`
Default accounts	`setup_db.py` falls back to admin password `oxypc@admin123`; `seed_uat_users.py` holds fixed UAT passwords for every role, including admin.	`setup_db.py:41-50`; `seed_uat_users.py`
HTTPS	Redirect to HTTPS only when a proxy sends `X-Forwarded-Proto`. `Secure` cookie flag off unless `OXYPC_COOKIE_SECURE=1`. LAN install runs on plain HTTP (`192.168.1.100:8000`, CLAUDE.md).	`main.py:54-80`; `config.py:39-43`
Uploads	Stored under `uploads/` (CRM files, accounts documents, GRN invoices, quotes, partner photos and bid documents, daily stock CSVs). The folder is mounted at `/uploads` **with no login check**.	`main.py:133-136`; `routers/accounts.py:45-56`; `routers/grn.py:34,626-631`; `routers/crm_quotes.py:608`; `routers/partner_admin.py:549,1653,2241`; `services/daily_stock_reports.py:4,28`
Upload names	Accounts / CRM: random UUID names, but any file extension is kept. GRN: `<grn_number>_<original name>`. Daily stock: `daily_stock_reports/<YYYY-MM-DD>/overall.csv` (predictable).	as above
Private uploads	Partner payment proofs are stored outside `uploads/` and served through a logged-in route.	`services/partner_service.py:24`; `routers/partner_admin.py:545-548`
`.gitignore` notes	`uploads/*` described as "CRM lists, IQC photos, KYC docs — PII".	`.gitignore:32-34`
Backups	`pg_dump` → gzip in `backups/` on the same host; not encrypted. Admin can list, download, run and delete backups (`oxypc_YYYYMMDD_HHMMSS.sql.gz`, path-traversal guarded). Production wrapper keeps all backups unless `OXYPC_BACKUP_PRUNE=1`; `scripts/backup.sh` keeps 30 days. Off-site copy is recommended but not automated.	`scripts/backup_db.py:26-27,88-95`; `routers/admin.py:609-735`; `deploy/oxypc-backup.sh:7-15`; `scripts/backup.sh:32,61-62`; `docs/backup-runbook.md`

9. Pricing and financial data policy

Policy (business decision, 1 Nov 2026): "Pricing and P&L data are visible to Admin/Management only, everywhere in the application."

"Everywhere" means screens, list columns, detail popups, the JSON endpoints used by pages, dashboard tiles, CSV/Excel/PDF exports, printouts, Reports (Business P&L, Lot P&L, Daily Stock value columns), Cost Config, Price Matrix, Product Pricing / Pricing Calculator, Lot buying price fields, IQC/GRN unit price fields and Part cost fields. Today the code does not comply: Pricing Visibility is on for every role by default and the P&L gate admits roles outside management (see R3, R6, R9 and the new R13 below).

9.1 Role set (confirmed by the Director, 1 Nov 2026)

Role	Buying price / cost / margin	Selling price	P&L reports	Cost Config, Price Matrix, Product Pricing
`admin`	Yes	Yes	Yes	Yes
`sub_admin` (custom, seeded)	Yes	Yes	Yes	Yes
`trc_manager` (custom)	Yes	Yes	Yes	Yes
Managers / Director role	Yes	Yes	Yes	Yes
`sales_manager`	No	Yes (may Set Price)	No	No
Accounts (custom)	No	Yes (selling price and invoice amounts, for invoicing and payments)	No	No
`sales` / `telecaller` (Sales Executive)	No	Yes, on Ready to Sale only	No	No
`iqc_inspector`	No	No	No	No
`inventory_manager`	No	No	No	No
Production Manager (`inventory_manager` acting as PM, or custom `production_manager`)	Parts cost only, for Lot Estimation (repair budget); no buying price or margin	No	No	No
`l1_engineer` , `l3_engineer` (Repair Engineers)	No	No	No	No
`qc_inspector` (QC Inspector, Final QC Inspector)	No	No	No	No
`cosmetic_manager` (Cosmetic Lead)	No	No	No	No

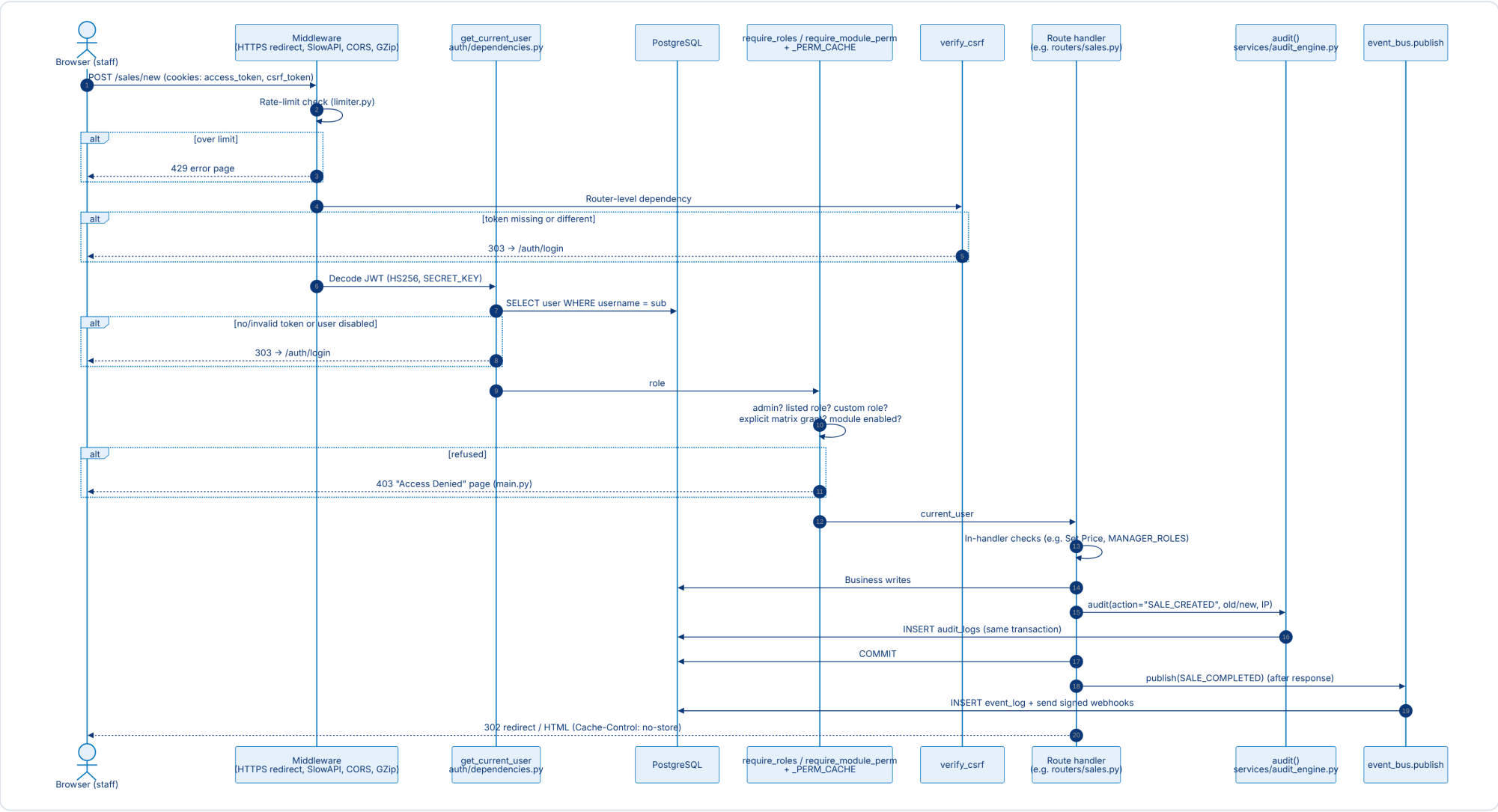
Role	Buying price / cost / margin	Selling price	P&L reports	Cost Config, Price Matrix, Product Pricing
`spare_parts_manager`	No	No	No	No
Any other custom role	No	No	No	No

9.2 Surfaces and required changes

Where prices appear	Current control	Required change
Screens, list columns, detail popups (21 templates, e.g. `templates/sales/list.html:171`, `templates/lots/list.html:81-117`, `templates/iqc/list.html:195-223`)	`can_view_pricing` per role, **default on** for every role; admin always sees prices (`models/role_permissions.py:83,189-193`; `templates_config.py:132-149`)	Default `can_view_pricing` = **off** for every role except the management roles in §9.1; split the switch so `sales_manager`, Accounts and Sales Executive can be granted selling price without buying price, cost or margin
JSON endpoints used by pages (`routers/sales.py:218,2112`; `routers/devices.py:527,1190`)	Same `can_view_pricing` check	Same default change; review every JSON endpoint that returns `buying_price`, `cost`, `margin` fields
Dashboard value tiles (financial-year summary, profit, stock value; `routers/dashboard.py`)	Not gated by Pricing Visibility	Gate value tiles by `can_view_pricing` (management roles only)
CSV/Excel exports: `/sales/export` (`routers/sales.py:2331`), `/sales/export-selected` (`:1953`), `/reports/export/sales` (`routers/reports.py:1121`), `/reports/export/lot-pl` (`:870`)	Not applied; Export/Download/Print switches stored but not read (R6)	Apply `can_view_pricing` in every export builder; strip price, cost and margin columns for non-management roles
Printouts (tax invoice, delivery challan, gate pass, labels)	Page gate only	Selling price and invoice amounts remain for Sales and Accounts; no buying price, cost or margin on any printout
Reports: Business P&L, Lot P&L	`_require_financials` = `admin`, `inventory_manager`, `sales_manager`; custom roles pass (`routers/reports.py:55-63`; `auth/dependencies.py:188-189`)	Restrict `_require_financials` to the management roles; close it to custom roles other than `sub_admin` and `trc_manager`
Reports: Daily Stock value columns	Router gate only (`routers/reports.py:43-47`)	Hide value columns unless `can_view_pricing`; keep counts for all roles that may open the report
Cost Config (`routers/admin.py:545,563`)	Module `cost_config`, permissive by default (R3)	Add `cost_config` to `DEFAULT_DISABLED_MODULES`; enable for management roles only

Where prices appear	Current control	Required change
Price Matrix (`routers/crm_price_matrix.py:25,55,67`)	Open to view for any signed-in user; edit by in-handler role tuple	Add to `DEFAULT_DISABLED_MODULES` ; view and edit for management roles only
Product Pricing / Pricing Calculator (`routers/product_master.py`)	Already in `DEFAULT_DISABLED_MODULES` (D)	Keep off; grant to management roles only
Lot buying price fields (`templates/lots/list.html` ; Lot Overview, GRN with Invoice)	`can_view_pricing` on screens; GRN/Lot pages open to `inventory_manager`	Hide buying price fields unless `can_view_pricing` ; lot creation by non-management roles records the price without displaying it, or management enters it
IQC/GRN unit price fields (`templates/iqc/list.html:195-223` ; `routers/grn.py`)	`can_view_pricing` on the IQC list only	Apply the same switch to GRN forms, IQC detail popups and IQC export (`routers/iqc.py:170-171`)
Part cost fields (Parts GRN, Part Master, Part Estimation; `routers/parts_grn.py` , `routers/spare_parts.py` , `routers/part_estimation.py`)	Not gated	Hide part cost and estimate value unless `can_view_pricing` ; Spare Parts Manager and Production Manager see quantities only
Per-user "View Device Buying / Cost Data" (`routers/admin.py:375-430` ; `models/user.py:133-143`)	Stored, never enforced	Enforce as an additional grant on top of the role default, or remove the tick
Pricing Visibility saves (`routers/master.py:946-986`)	Not audited (R5)	Write an `audit()` row for every Pricing Visibility, Set Price and `_require_financials` -related change

10. Request flow



FastAPI resolves router-level and route-level dependencies before the handler; the order between CSRF and auth shown above is illustrative. Sources: `main.py:34-109`, `auth/dependencies.py:93-343`, `routers/sales.py:67,79,1372-1400`, `services/audit_engine.py`, `services/event_bus.py:53-78`.

11. Known risks and recommendations

Severity is our judgement from reading the code. "Verify" means a live test should confirm it before acting.

#	Risk	Evidence	Severity	Recommendation
R1	**Uploaded files are public.** `/uploads` is served with no login. It holds accounts documents, CRM files, GRN invoices, quotes, partner bid POs and daily stock CSVs at predictable paths.	`main.py:133-136` ; `services/daily_stock_reports.py:4,28` ; `routers/grn.py:628`	High	Serve these files through a logged-in route with a permission check (as partner proofs already are). Keep only public marketing photos on a static mount.
R2	**Uploads keep any file type** and are served from the app's own origin. An uploaded `.html` file could run script in the app's origin (where `csrf_token` is readable).	`routers/accounts.py:45-56` ; `routers/crm_contacts.py:80-90`	High (verify)	Allow-list extensions and content types; serve downloads with `Content-Disposition: attachment` .
R3	**Permissive defaults.** A role or module with no matrix row is allowed. A new custom role (including the auto-seeded `sub_admin`) passes every non-admin `require_roles` gate. Sensitive modules such as Cost Config and Credit Note are open by default, against the pricing policy in §9.	`models/role_permissions.py:234-238` ; `auth/dependencies.py:188-189` ; `main.py:582-597` ; `routers/admin.py:545`	High	Make custom roles deny-by-default; add sensitive modules (including Cost Config, Price Matrix, Product Pricing) to `DEFAULT_DISABLED_MODULES` ; require a matrix save when creating a role.
R4	**Admin-equivalent grants.** An explicit `admin_master` or `admin_users` grant passes the admin-only gate on the Permission Matrix and User Management, so the holder can grant itself more or create an `admin` user. The comment in `auth/dependencies.py:117-120` says `/admin/master` is not a matrix module, but `routers/landing_pages.py:177` maps it.	`auth/dependencies.py:147-172,190-196` ; `routers/landing_pages.py:176-177` ; `routers/admin.py:190-236` (role is free text)	High (verify)	Keep `/admin/master` and `/admin/users` strictly admin, or block a non-admin from granting itself or assigning `admin` .
R5	**Permission changes are not audited**, and `audit_logs` is append-only only by convention. Audit IP uses the left-most `X-Forwarded-For` value, which a client can set.	`routers/master.py` (no `audit()`); `models/engines.py:109-110` ; `services/audit_engine.py:40-43`	Medium	Audit every matrix/role/pricing save and password reset; `REVOKE UPDATE, DELETE` on `audit_logs` for the app user; use the same IP logic as `limiter.py:11-29` .

#	Risk	Evidence	Severity	Recommendation
R6	**Pricing leaks through exports.** Pricing Visibility hides screens but not CSV exports. Export/Download/Print/Upload switches and per-user `UserPermission` grants are stored but never enforced. The policy in §9 requires prices to be stripped from every export and printout for non-management roles.	`routers/sales.py:1953,2331` ; `routers/reports.py:870,1121` ; `routers/master.py:313-325` ; `routers/admin.py:375-430`	Medium	Apply `can_view_pricing` in export builders (`/sales/export` , `/sales/export-selected` , `/reports/export/sales` , `/reports/export/lot-pl`); enforce or remove the unused switches.
R7	**Weak defaults in config and seed scripts**: default DB password, default OxyQC key (compared without constant time), default admin password, UAT passwords in the repo; `Secure` cookie flag off by default; LAN runs on HTTP.	`config.py:27,41-45` ; `routers/iqc_api.py:39-40` ; `setup_db.py:41-50` ; `seed_uat_users.py`	Medium	Refuse to start with default secrets in production; use `hmac.compare_digest` ; enable HTTPS and `OXYPC_COOKIE_SECURE=1` ; disable UAT accounts in production.
R8	**Sessions cannot be revoked.** 24 h JWT, extendable from the page; logout only clears cookies; password change does not end other sessions. Password rules: 6 characters on self-change, none on admin create/reset.	`config.py:33` ; `routers/auth.py:125-145,194,208-234` ; `routers/admin.py:359-372`	Medium	Add a token version per user (as the partner portal does with `pv` , `auth/partner_auth.py:31,70`); raise the password policy.
R9	**Code and matrix disagree.** In-handler role tuples refuse custom roles that `require_roles` lets in (Finance, Purchase Orders, Price Matrix edit, Returns approval). `stage_allowed()` is dead code, so repair pages are open to all. `sales_manager` is missing from the reports router gate.	`routers/accounts.py:31` ; `routers/crm_purchase_orders.py:26-29` ; `routers/repair.py:76-85` ; `routers/reports.py:43-47`	Medium	Replace in-handler tuples with `require_roles` / `role_allowed` ; remove or wire `stage_allowed()` ; align the reports gate.
R10	**Multi-worker side effects.** With 4 workers, the in-memory limiter allows about 4× the stated limits and permission changes take up to 60 s to apply everywhere.	`deploy/oxypc.service:28` ; `limiter.py:74` ; `main.py:789-829`	Low	Use a shared limiter store (e.g. Redis) or keep 1 worker; refresh caches on save across workers.
R11	**CSRF gaps** on a few cookie-authenticated POSTs.	§4 table	Low (SameSite=strict mitigates)	Add `verify_csrf` to `routers/qa_uat.py` , `routers/api_v1/*` cookie routes and `generate-po` .
R12	**Lockout can be abused.** Five wrong passwords lock a known username for 15 minutes.	`routers/auth.py:75-88`	Low	Lock per username + IP, or add a CAPTCHA after failures.

#	Risk	Evidence	Severity	Recommendation
R13	**Pricing visible to all roles by default; policy requires management-only.** `can_view_pricing` defaults on for every role, the P&L gate admits `inventory_manager`, `sales_manager` and any custom role, dashboard value tiles and exports are not gated, and Cost Config and Price Matrix are open. The business policy of 1 Nov 2026 limits pricing and P&L to Admin/Management everywhere.	§9; `models/role_permissions.py:83,189-193`; `routers/reports.py:55-63`; `auth/dependencies.py:188-189`; `routers/admin.py:545`	High	Implement the changes in §9.2: default `can_view_pricing` off except management roles; restrict `_require_financials` and close it to custom roles; gate exports, printouts, dashboard tiles and part/lot/GRN cost fields; default-off Cost Config, Price Matrix, Product Pricing; audit Pricing Visibility saves. Confirm the role set in §9.1 with the Director.

12. Open questions

1. Is production actually on HTTPS, and is `OXYPC_COOKIE_SECURE=1` set? (`deploy/nginx-oxypc.conf:6` suggests Let's Encrypt for `erp.oxypc.in`; the LAN server runs HTTP.)
2. Are the default `SECRET_KEY`, DB password and OxyQC key replaced in every environment? Are UAT accounts present in production?
3. Which deployment is live: 1 worker (`Dockerfile:73`) or 4 workers (`deploy/oxypc.service:28`)?
4. Is there a retention rule for `audit_logs`, `login_logs`, `event_log` and `errors.log`? None exists in code.
5. Does the nginx front end block `/uploads` for non-public folders? The configs in `deploy/` do not mention `/uploads`.
6. Are backups copied off the server and encrypted? `docs/backup-runbook.md` recommends it; no script does it.
7. Is the `admin_master` / `admin_users` grant (R4) used in production, and by whom?
8. Should `audit_logs` be protected at the database level?
9. With `forwarded_allow_ips="*"` (`main.py:867`), what does `request.client.host` hold behind the proxy? It feeds `login_logs.ip_address` (`routers/auth.py:95,106`).